

AITIR Framework Version 2.0 Future Development Plan

A staged program for moving from a technically specified reference architecture to reproducible artifacts, controlled research, and, only if authorized evidence supports it, restricted operational capability.

Author: Md Sazzad Hossain

Affiliation: School of Business and Technology, Emporia State University

ORCID: 0009-0009-4948-1179

Plan version: 2.0.0 · 5 August 2026

Repository: <https://github.com/sajjad47/AITIR-Framework>

Program rule: Progression is earned by evidence. Documentation does not become implementation by adding features, and a synthetic benchmark does not become operational assurance by adding claims.

This plan is a research and engineering roadmap. It does not represent funded work, a government commitment, a production deployment, a compliance determination, or a promise of performance.

1 · Version 2 Baseline and Program Controls

Baseline delivered in Version 2.0

7-plane architecture

5 trust zones

event/evidence/decision schemas

T0-T3 authority

12 guard categories

state machine

migration guide

standards crosswalk

research ledger

automated validation

The repository establishes Level L0 documentation and selected L1 artifacts. It contains no production implementation, trained model, live telemetry, enforcement connector, field validation, or system authorization.

Decision gates

Gate	Decision	Required evidence
G0 Architecture	Is the design coherent enough to implement?	threat model, trust boundaries, contracts, owners, authority, limitations
G1 Artifact	Do reference components conform?	schema, policy, state, security, reproducibility and negative tests
G2 Research	Can claims survive chronological controlled evaluation?	frozen protocol, leakage control, uncertainty, sensitivity, independent review
G3 Pilot	May shadow/advisory use begin?	lawful purpose, approvals, privacy, records, labor, accessibility, continuity
G4 Restricted action	May narrow T0/T1 or approved T2 execute?	authorization, guard tests, fault injection, rollback, monitoring, stop criteria
G5 Sustain/stop	Should capability continue, narrow, roll back, or end?	multi-period outcomes, incidents, harms, burden, cost, reassessment

Cross-cutting governance

- mission and system owner
 - identity and incident-response owner
 - privacy, legal, records and civil-rights review
 - labor and accessibility review where applicable
- model-risk validation
 - secure development and supply-chain controls
 - continuity and recovery owner
 - independent assessment and authorization

Prohibited shortcut: No phase may give analytics direct enforcement credentials or treat an AI explanation, threat indicator, graph rank, or playbook as response authority.

2 · Phased Technical Work

Phase 2.0.x · Documentation hardening

External review, machine-readable mappings, schema examples, decision vectors, diagram/PDF provenance, release signing, and issue remediation.

Exit: examples validate; generated artifacts reproduce; no unresolved high-severity ambiguity.

Phase 2.1 · Local reference implementation

Separate event, evidence, decision, and enforcement privilege domains; deterministic baseline; immutable decision records; simulated connectors and rollback; SBOM, threat model, model/data cards.

Exit: automated security and conformance suite passes; analytics has no enforcement path.

Phase 2.2 · Offline research harness

Chronological replay, leakage-safe feature construction, calibration, abstention and queue-cost analysis, uncertain identity graphs, source/model/feedback adversarial tests, and uncertainty intervals.

Exit: frozen reproducible benchmark with negative results and external-validity limits.

Phase 2.3 · Controlled pilot package

Impact-assessment templates, local T0-T3 catalog, tabletop/offline/shadow procedures, analyst workflow instrumentation, connector fault injection, continuity and independent-assessment package.

Exit: authorized shadow mode only; no state-changing automation.

Phase 2.x pilot · Advisory then narrow controls

Advance from live shadow to advisory, then narrowly preapproved T0/T1. Restricted T2 is considered only after independent evidence and explicit authorization. T3 remains named-human authorized.

Exit: sustained thresholds, safe failure, rollback, queue capacity, privacy and mission outcomes.

Version 3 trigger

A major version is considered only when controlled evidence reveals a necessary incompatible change to object contracts, authority semantics, or response state. Marketing cadence is not a valid trigger.

3 · Research and Evaluation Work Packages

Work package	Primary outputs	Failure questions
Telemetry and identity fabric	source maps, schema adapters, health metrics, uncertain resolution	loss, drift, replay, false join, cross-tenant leak
Calibrated analytics	model/data cards, chronological benchmark, calibration, uncertainty	overconfidence, unknown attack, leakage, temporal decay
Selective review	coverage-risk, queue simulation, reviewer protocol, cost sensitivity	overload, delay, disagreement, automation bias, selective labels
Identity graph	relation-confidence model, remediation ranking, cost definition	spurious/missing edge, wasted action, service disruption
Response authority	local decision table, state machine, reason codes, test vectors	bypass, stale/replayed decision, separation failure, break-glass abuse
Orchestration	simulated connectors, idempotency, evidence preservation, rollback	race, duplicate, partial failure, false success, irreversible harm
Assurance and resilience	release gates, SBOM, drift, incidents, degraded modes, recovery	unsafe fail-open/closed, poisoned feedback, unsupported claim

Minimum measurement set

Analytical

- precision-recall and family recall
- false alerts per operational unit
- Brier score and reliability
- coverage-risk and abstention rate
- uncertainty intervals

Operational safety

- unauthorized actions
- queue age and burden
- rollback and evidence preservation
- duplicate/partial action
- mission and privacy impact

Protocol discipline: Fit on training only, choose model/calibration/threshold/coverage on validation only, evaluate once on a later holdout, and disclose every deviation.

Research module boundaries

Current AITIR studies provide bounded starting evidence for architecture, abstention, graph remediation, and response verification. They do not supply a universal production policy, real-world relation-confidence model, perfect reviewer, or live safety guarantee.

4 · Pilot Governance, Risk and Stop Criteria

Required local artifacts

- system boundary, data-flow and trust-boundary diagrams;
- purpose, authority, privacy, records, labor, accessibility and continuity decisions;
- local identity, asset, entitlement and connector inventory;
- local T0-T3 action catalog and authority matrix;
- data/model/policy/playbook/connector cards and release approvals;
- abstention queue owner, service objective, capacity and fallback;
- incident, evidence, rollback, break-glass and appeal procedures;
- independent assessment and residual-risk acceptance.

Stop or roll back when

Trigger	Required response
analytics gains direct enforcement authority	stop immediately; revoke privilege; investigate control failure
unauthorized, expired, replayed or duplicate action	contain, preserve evidence, roll back, suspend affected tier
queue exceeds approved age/capacity	activate approved fallback; reduce coverage or automation
source/model/calibration degradation exceeds threshold	enter deterministic degraded mode; revalidate
material privacy, accessibility, labor, civil-rights or mission harm	stop affected use; notify owner; investigate and remediate
connector cannot verify target state or rollback	treat as failed/unknown; block retry pending refreshed decision
evidence cannot reproduce a material claim	withdraw or correct claim and generated materials

Safe degraded operation

Loss of a source, model, policy service, identity provider, network, or connector enters an explicit mode. The default is neither unrestricted access nor indiscriminate denial. Approved deterministic policy, stronger verification, narrow mission continuity, and time-bound break-glass are used as authorized.

Human review is not a universal safety net. Reviewers can be overloaded, biased, inconsistent or missing key evidence. Their performance and the consequences of delay must be measured.

5 · Deliverables, Resourcing and Claim Discipline

Deliverable families

Family	Examples
Architecture	requirements, diagrams, threat model, contracts, interoperability mappings
Reference software	local services, schemas, policy engine, simulators, validation and test suites
Research	frozen protocols, benchmark code, lawful datasets or generators, analysis and negative results
Governance	authority matrix, impact assessments, data/model/policy cards, risk and exception registers
Assurance	SBOM, security tests, independent assessment, incidents, release hashes and signatures
Pilot	tabletop, offline, shadow, advisory and restricted-operation packages with stop criteria

Capability roles

Work requires security and identity architecture, incident response, data engineering, ML/statistics, graph methods, privacy/legal/records expertise, accessibility and human factors, secure software engineering, continuity planning, independent testing, and mission ownership. One model-development team cannot substitute for these roles.

Claim ladder

1. **Proposed:** architectural requirement or hypothesis.
2. **Implemented:** source and tests exist.
3. **Reproduced:** checked-in artifacts regenerate.
4. **Validated:** frozen target-environment protocol supports a bounded claim.
5. **Authorized:** accountable official accepts residual risk for stated use.
6. **Assured:** sustained monitoring and independent reassessment continue.

Never collapse the ladder. “AI-powered,” “zero trust,” standards mapping, publication, or successful synthetic testing does not mean production-safe, compliant, approved, or autonomous.

Program non-goals

- unrestricted autonomous response;
- silent self-training or policy mutation;
- replacement of identity providers, SIEM, SOAR, case management or authorization;
- collection of real protected data in the public repository;
- performance, savings or public-sector impact claims without evidence.

Canonical framework citation: Hossain, M. S. (2026). *AITIR Framework: Adaptive Identity-and-access Threat Intelligence and Response* (Version 2.0.0). <https://github.com/sajjad47/AITIR-Framework>

Generated 5 August 2026. Full roadmap, specification, schemas, research ledger and validation are maintained in the repository.